

# Modos de operación

---

El modo determina cómo una primitiva protege mensajes, qué exige del nonce y si aporta autenticidad.

Material elaborado por el profesor Sergio Gevatschnaider

# Contenido

|                                              |          |
|----------------------------------------------|----------|
| <b>Propósito</b>                             | <b>3</b> |
| <b>Resultados de aprendizaje</b>             | <b>3</b> |
| <b>Núcleo teórico</b>                        | <b>3</b> |
| Nonce, IV y contador . . . . .               | 3        |
| Encrypt-then-MAC y AEAD . . . . .            | 3        |
| <b>Profundización y criterio profesional</b> | <b>3</b> |
| <b>Caso de análisis</b>                      | <b>4</b> |
| Entrega esperada . . . . .                   | 4        |
| <b>Riesgos y errores frecuentes</b>          | <b>4</b> |
| <b>Actividades de dominio</b>                | <b>4</b> |
| <b>Lista de comprobación</b>                 | <b>4</b> |
| <b>Referencias seleccionadas</b>             | <b>4</b> |

## Propósito

El modo determina cómo una primitiva protege mensajes, qué exige del nonce y si aporta autenticidad.

## Resultados de aprendizaje

1. comparar ECB, CBC, CTR, GCM y XTS.
2. elegir AEAD.
3. diseñar nonce, AAD y tratamiento del tag.

## Núcleo teórico

| Modo              | Garantía                                 | Condición crítica                                                   |
|-------------------|------------------------------------------|---------------------------------------------------------------------|
| ECB               | No oculta estructura repetida            | Evitar                                                              |
| CBC               | Confidencialidad si se usa correctamente | IV apropiado y MAC separado                                         |
| CTR               | Confidencialidad tipo flujo              | Contador/nonce no repetido                                          |
| GCM               | AEAD: confidencialidad, integridad y AAD | Nonce único por clave                                               |
| XTS               | Protección de sectores                   | No sustituye AEAD general                                           |
| ChaCha20-Poly1305 | AEAD de flujo                            | Nonce único por clave y verificación del tag antes de usar el texto |

La recomendación general para datos y protocolos es preferir AEAD, por ejemplo AES-GCM o ChaCha20-Poly1305.

### Nonce, IV y contador

No son sinónimos universales. Un IV puede requerir imprevisibilidad, unicidad o ambas propiedades según el esquema. Un nonce significa “número usado una vez” dentro del alcance que define el protocolo. En GCM y ChaCha20-Poly1305, repetir el nonce con la misma clave puede destruir las garantías de confidencialidad y autenticidad.

Una estrategia segura debe especificar quién genera el nonce, cómo se evita la colisión, qué ocurre después de un reinicio, cómo se particiona el espacio entre emisores y cuándo se rota la clave.

### Encrypt-then-MAC y AEAD

Una composición heredada segura puede cifrar y luego autenticar el ciphertext junto con metadatos relevantes usando claves separadas. AEAD integra esa interfaz y reduce el espacio para errores. AAD permite autenticar campos que deben permanecer visibles, como versión de protocolo, identificador de sesión o encabezado de paquete.

## Profundización y criterio profesional

ECB filtra igualdad de bloques y no debe utilizarse para mensajes. CBC y CTR aportan confidencialidad bajo condiciones precisas, pero no autenticidad. GCM combina CTR con autenticación polinómica; XTS protege sectores y no reemplaza una interfaz AEAD general.

El nonce de GCM debe ser único bajo una clave. La AAD vincula metadatos visibles, como versión, dirección, identificador de sesión y tipo de mensaje. El receptor debe rechazar antes de usar cualquier texto cuando el tag falla.

| Construcción | Padding | Autenticidad          | Uso típico                |
|--------------|---------|-----------------------|---------------------------|
| CBC          | Sí      | Requiere MAC separado | Compatibilidad controlada |

| Construcción | Padding        | Autenticidad          | Uso típico         |
|--------------|----------------|-----------------------|--------------------|
| CTR          | No             | Requiere MAC separado | Flujo con contador |
| GCM          | No             | Sí, AEAD              | Datos y protocolos |
| XTS          | No tradicional | No general            | Sectores de disco  |

## Caso de análisis

Defina un formato de paquete AES-GCM con versión, identificador de clave, salt opcional, nonce, AAD, ciphertext y tag. Explique qué campos se autentican y cuáles deben ser únicos.

### Entrega esperada

Documento activos, actores, propiedad, parámetros, flujo, condición de fallo y decisión recomendada. Separe siempre la garantía criptográfica de la garantía operativa.

## Riesgos y errores frecuentes

- usar ECB.
- procesar texto antes de verificar el tag.
- generar nonces sin considerar reinicios.

## Actividades de dominio

1. ¿Por qué XTS no sustituye GCM?
2. ¿Qué diferencia hay entre AAD y ciphertext?
3. ¿Qué ocurre al repetir nonce en GCM?

## Lista de comprobación

- Puedo definir la propiedad y el adversario.
- Puedo explicar parámetros, límites y supuestos.
- Puedo detectar al menos tres configuraciones inseguras.
- Puedo justificar una decisión de arquitectura.
- Puedo relacionar el tema con una norma o especificación primaria.

## Referencias seleccionadas

1. NIST SP 800-38A - <https://doi.org/10.6028/NIST.SP.800-38A>
2. NIST SP 800-38D - <https://doi.org/10.6028/NIST.SP.800-38D>